A

APEX

Manual de seguridad

Políticas de acceso y contraseñas, controles implementados, auditoría, respaldos, respuesta a incidentes y tratamiento de datos personales.

Dirigido a: dueño del negocio, administradores y soporte técnico

APEX · Sistema de control de cobros
Versión 1.3 · octubre de 2026

Desarrollado por
Ing. Antony Pérez

Contenido

1. Objetivo y alcance

2. Política de acceso

   2.1 Usuarios

   2.2 Permisos por rol

3. Política de contraseñas

4. Protección de sesiones y del ingreso

5. Controles técnicos implementados

   5.1 Datos guardados en los celulares

   5.2 Pruebas de seguridad

6. Auditoría

   6.1 Revisión recomendada

7. Respaldos

8. Respuesta a incidentes

9. Tratamiento de datos personales

10. Recomendaciones para el servidor

1. Objetivo y alcance

APEX maneja dinero y datos personales de clientes. Este manual define las reglas para proteger la **confidencialidad** (solo quien debe ve la información), la **integridad** (nadie altera los registros sin dejar rastro) y la **disponibilidad** (la información no se pierde) del sistema.

Aplica a todas las personas con usuario en el sistema y a quienes administran el servidor donde está instalado.

2. Política de acceso

2.1 Usuarios

- Cada persona tiene **un usuario personal**. Está prohibido compartir usuarios o contraseñas.
- Se asigna el **mínimo privilegio**: los cobradores tienen rol Cobrador; solo el dueño y quien maneja la caja tienen rol Administrador.
- Cuando una persona deja de trabajar, su usuario se **desactiva el mismo día** (sus sesiones se cierran en ese instante).
- Se recomienda tener **dos administradores** para no depender de una sola persona.

2.2 Permisos por rol

Los permisos se validan en el servidor en cada petición; ocultar un botón no es la protección, la regla del servidor sí lo es.

Información o acción	Administrador	Cobrador
Clientes, créditos, pagos y documentos	**Todos**	**Solo de su cartera**
Registrar pagos	**Sí, con fecha anterior**	**Solo con fecha y hora actuales, a su nombre (sin conexión: la hora del cobro, máximo 7 días atrás y nunca en un día con caja cerrada)**
Ordenar la ruta	**De cualquier cobrador**	**Solo la suya**
Crear, renovar y anular créditos; anular pagos	**Sí**	**No**
Asignar clientes, cambiar estados	**Sí**	**No**
Cerrar cajas	**Sí**	**No**
Reportes, usuarios, configuración, auditoría y respaldo	**Sí**	**No**

3. Política de contraseñas

Longitud	Mínimo 10 caracteres (máximo 128).
Complejidad	Mayúsculas y minúsculas, al menos un número y un símbolo.
Prohibido	Contener el usuario, nombre, cédula o correo; palabras comunes (password, admin, colombia, 123456…, también con sustituciones como "4dm1n"); repetir un carácter 4 o más veces seguidas; reutilizar la contraseña actual.
Primer ingreso	Toda contraseña asignada por el administrador (usuario nuevo o restablecido) debe cambiarse en el primer ingreso. El sistema no permite usar ninguna otra pantalla hasta hacerlo.
Almacenamiento	Nunca se guarda la contraseña: se guarda un resumen irreversible Argon2id. Ni el administrador ni el desarrollador pueden ver las contraseñas.
Al cambiarla	Se cierran las demás sesiones abiertas del usuario.

✓ **Recomendaciones:** usa una frase de varias palabras con símbolos (`Cafe.Tinto#Martes19`), no la anotes en papel visible, no la uses en otros sitios y cámbiala si sospechas que alguien la conoce.

4. Protección de sesiones y del ingreso

Control	Funcionamiento
Bloqueo por intentos	5 intentos fallidos en 15 minutos bloquean el ingreso de ese usuario desde ese equipo; 10 bloquean al usuario desde cualquier equipo; 20 bloquean al equipo para cualquier usuario. Se registra en la base de datos, así que borrar las cookies no lo evita.
Mensaje genérico	"Usuario o contraseña incorrectos" en todos los casos, con el mismo tiempo de respuesta, para no revelar qué usuarios existen.
Inactividad	La sesión se cierra tras 30 minutos sin uso y como máximo a las 12 horas.
Revalidación constante	En cada pantalla se verifica que el usuario siga activo, con el mismo rol y la misma contraseña. Desactivarlo, cambiarle el rol o la contraseña tiene efecto inmediato en sus sesiones abiertas.
Robo de sesión	Cookie inaccesible a JavaScript (HttpOnly), restringida al sitio (SameSite), cifrada con HTTPS (Secure), identificador nuevo al ingresar y ligado al navegador.

5. Controles técnicos implementados

Riesgo	Protección
Acceso a datos de otro cobrador cambiando la dirección (IDOR)	Cada consulta verifica que el registro pertenezca a la cartera del usuario.
Envío de formularios desde otros sitios (CSRF)	Token secreto en cada formulario; las acciones que cambian datos solo se aceptan por POST.
Inyección SQL	Consultas preparadas en todo el sistema.
Inyección de código en pantallas (XSS)	Todo dato se escapa al mostrarse y la política CSP solo permite los scripts propios del sistema.
Inserción en otro sitio (clickjacking)	El sistema no se puede mostrar dentro de otras páginas.
Fórmulas maliciosas en Excel	Los textos se guardan como texto literal y nunca se ejecutan.
Montos manipulados	Validación estricta: no se aceptan negativos, decimales, texto ni pagos mayores al saldo.
Descarga de archivos internos	Configuración, código, base de datos, registros, respaldos, pruebas y manuales fuente están bloqueados desde el navegador.
Exposición de errores internos	Con `APP_DEBUG=false` los errores se registran en el log y el usuario ve un mensaje genérico.
Modificación oculta del dinero	Los pagos nunca se borran: se anulan con motivo; los saldos se recalculan desde los pagos y todo queda auditado.
Cobros duplicados al sincronizar	Cada cobro o gestión de la ruta lleva un código único; si llega dos veces (mala señal, dos pestañas) se registra una sola.
Cobros sin conexión manipulados en el celular	El celular no decide nada: al sincronizar, el servidor vuelve a aplicar todas las reglas (cartera propia, crédito activo, valor ≤ saldo, token CSRF y sesión válida del mismo usuario). Una hora del celular futura o de más de 7 días se reemplaza por la del servidor, y un pago no puede caer en un día con caja ya cerrada.

5.1 Datos guardados en los celulares

Para trabajar sin internet, cada equipo guarda copias de las pantallas abiertas (con datos de clientes) y, en la ruta, los cobros pendientes por enviar.

- Las copias de pantallas **se borran al cerrar sesión**. Los cobros pendientes no se borran, para no perder dinero registrado; solo los ve y los envía el mismo usuario.
- Nunca se guardan descargas (Excel, respaldos) ni la pantalla de ingreso.
- Las copias solo se ven **en ese equipo** y con el navegador abierto en APEX; no dan acceso al sistema: cualquier acción necesita una sesión válida en el servidor.

> ! **Límite:** desactivar un usuario cierra sus sesiones en el servidor, pero **no puede borrar a distancia** las copias que ya están en su celular. Por eso: celular con bloqueo de pantalla (PIN o huella), cerrar sesión al terminar la jornada, no usar APEX en equipos compartidos sin cerrar sesión, y no usar modo incógnito ni equipos ajenos.

5.2 Pruebas de seguridad

El sistema incluye 93 pruebas automáticas de seguridad (`tests/seguridad.php`). En la versión 1.3 se superaron las 93, en estas categorías:

Categoría	Pruebas	Ejemplos
Configuración y exposición de información	19	Archivos internos bloqueados, cabeceras de seguridad, cookies, caché
Autenticación y sesiones	15	Fuerza bruta, enumeración, fijación de sesión, contraseñas débiles, Argon2id
Control de acceso (roles e IDOR)	11	Escalada de privilegios, acceso a carteras ajenas, campos ocultos manipulados
Inyección, XSS, CSRF y validación	18	24 variantes de inyección SQL, XSS almacenado y reflejado, montos inválidos
Caja, gestiones, renovaciones, documentos, respaldo y manuales	28	Cierres solo por administrador, integridad de renovaciones, IDOR en documentos y manuales
Trazabilidad	2	Auditoría activa, sin errores internos expuestos

6. Auditoría

Toda acción relevante se registra con usuario, fecha y hora, dirección IP y navegador. Solo los administradores pueden consultarla (**Auditoría**) y nadie puede editarla desde el sistema.

Grupo	Eventos registrados
Acceso	Inicio de sesión, ingreso fallido, ingreso bloqueado, cierre de sesión, sesión expirada o invalidada, acceso denegado, cambio de contraseña
Usuarios	Creado, editado (incluye cambios de rol, estado y contraseña restablecida), activado/desactivado, eliminado
Clientes	Creado, editado, eliminado, asignación y traslado de cartera
Créditos y pagos	Crédito creado, renovado y anulado; pago registrado y anulado (con motivo)
Cobro y caja	Gestión de cobro, gasto registrado y anulado, cierre de caja (con diferencia), orden de ruta actualizado. Los cobros y gestiones que llegaron sin conexión se marcan "sin conexión" con la hora en que se sincronizaron.
Administración	Configuración modificada, exportación de reportes, respaldo de datos

6.1 Revisión recomendada

- ☐ **Diaria:** el resumen de las últimas 24 horas (ingresos fallidos, bloqueos, accesos denegados).
- ☐ **Semanal:** todos los **pagos anulados** y los **cierres con faltante**, verificando que el motivo sea razonable. También los pagos **sin conexión** sincronizados mucho después del cobro.
- ☐ **Mensual:** las **exportaciones** de datos y los cambios de usuarios y configuración.

> ! **Señales de alerta:** muchas anulaciones de un mismo usuario, pagos anulados poco después de registrados, ingresos fallidos repetidos, ingresos en horarios inusuales, exportaciones de clientes no solicitadas.

7. Respaldos

- **Frecuencia:** respaldo automático diario (ver Manual de instalación) más uno manual antes de cualquier cambio importante.
- **Regla 3-2-1:** 3 copias, en 2 medios distintos, 1 fuera de la oficina.
- **Retención:** respaldos diarios de 30 días y uno mensual por al menos un año.
- **Protección:** los respaldos contienen datos personales y resúmenes de contraseñas. Guárdalos en carpetas con acceso restringido o comprimidos con contraseña.
- **Prueba:** restaura un respaldo una vez al mes en una base de prueba.

8. Respuesta a incidentes

Situación	Qué hacer
Un cobrador perdió el celular o se lo robaron	1. Desactivar su usuario o asignarle una contraseña nueva (sus sesiones se cierran al instante). 2. Revisar en la auditoría su actividad reciente. 3. Preguntarle qué cobró sin señal: lo pendiente en ese celular no llegará; registrarlo en oficina. 4. Tener en cuenta que las copias de pantallas en ese celular pueden mostrar datos de sus clientes; si el equipo tenía cuenta de Google o Apple, borrarlo a distancia. 5. Reactivarlo con contraseña temporal cuando tenga equipo nuevo.
Sospecha de que alguien conoce una contraseña	Cambiarla de inmediato y revisar la auditoría de ese usuario.
Muchos ingresos fallidos o bloqueos	Identificar el usuario y la IP en la auditoría. Si no fue el usuario legítimo, cambiar su contraseña y avisar al soporte técnico.
Pagos anulados o datos modificados sin explicación	Revisar la auditoría (quién, cuándo, motivo). Si fue indebido, desactivar el usuario, restablecer las contraseñas de los administradores y, si es necesario, comparar con un respaldo anterior.
Pérdida o daño del equipo servidor	Instalar APEX en otro equipo (Manual de instalación) y restaurar el último respaldo. Cambiar todas las contraseñas.
Sospecha de acceso no autorizado al servidor	Desconectarlo de la red, sacar un respaldo, cambiar las contraseñas de Windows, de MySQL y de todos los administradores, y revisar con soporte técnico.

Documenta cada incidente: fecha, qué ocurrió, cómo se detectó, qué se hizo y qué se cambió para que no se repita.

9. Tratamiento de datos personales

APEX almacena datos personales de clientes (identificación, contacto, dirección, ocupación, referencias) e información financiera. En Colombia su tratamiento está regulado por la **Ley 1581 de 2012** y sus decretos reglamentarios. Estas son recomendaciones generales; consulta con un asesor legal para tu caso particular.

- **Autorización:** obtén la autorización previa, expresa e informada del cliente para el tratamiento de sus datos, y consérvala.
- **Finalidad:** usa los datos solo para la gestión del crédito y su cobro, como se le informó al cliente.
- **Referencias personales:** informa al cliente que registras los datos de su referencia y úsalos solo para su localización.
- **Acceso restringido:** cada cobrador ve únicamente a sus clientes; no exportes ni compartas listados sin necesidad.
- **Derechos del titular:** atiende las solicitudes de consulta, actualización y rectificación (los datos se editan en la ficha del cliente).
- **Cobranza respetuosa:** los mensajes de WhatsApp y las visitas deben respetar la dignidad del cliente; no compartas su deuda con terceros.
- **Seguridad:** aplica las políticas de este manual (contraseñas, respaldos protegidos, desactivación oportuna de usuarios).

10. Recomendaciones para el servidor

- ☐ `APP_DEBUG=false`.
- ☐ Usuario de MySQL propio con contraseña; contraseña también para `root`.
- ☐ HTTPS si el sistema se publica en internet (también es obligatorio para trabajar sin conexión).
- ☐ `ServerTokens Prod` y `ServerSignature Off` en Apache.
- ☐ Windows actualizado, antivirus activo y cuenta de Windows con contraseña.
- ☐ phpMyAdmin accesible solo desde el propio equipo.
- ☐ Ejecutar `tests/verificar_produccion.php` cada mes.